PLATFORM COMPLIANCE BRIEF

CRM Sync — Shopify App Platform Changes

For product managers, operations, and business stakeholders. **Apps built under the old rules fail submission under the new requirements** — legacy Partner Dashboard apps, non-expiring access tokens, and undeclared field-level customer-data access all need updating before publication or re-review.

For: **Product managers, operations teams, and business stakeholders tracking Shopify app compliance**

Date: **2026-05-18**

The Problem

Shopify has fundamentally changed how apps are built, authenticated, and reviewed. Apps built under the old rules will fail submission under the new requirements — and some deadlines have already passed.

If your app was created in the legacy Partner Dashboard, uses non-expiring access tokens, or manages customer data without declaring specific field-level access, it needs to be updated before it can be published or pass re-review.

These are not optional enhancements. They are platform requirements with enforcement dates.

What Changed

AREA	OLD WAY (PARTNER DASHBOARD)	NEW WAY (DEV DASHBOARD)	DEADLINE
Access tokens	Never expire — store once, use forever	Expire every 60 minutes — must refresh automatically	**April 1, 2026** (mandatory for new public apps)
Customer data access	Request "read customers" → get everything	Request specific fields: name, email, phone, address — each justified separately	Enforced on submission
App configuration	Web forms in dashboard — no version history	Config file in code repository — version controlled, reviewable	Current standard
GDPR compliance	Optional checkbox for data deletion webhooks	Mandatory — must handle data requests, customer deletion, and shop deletion	Enforced on submission
Consent management	Not required by platform	Customer Privacy API required — consent signals before data collection	2025-2026 enforcement
Billing	REST API for charges	GraphQL API for subscriptions with upgrade/downgrade support	Current standard
App review	Submit and wait weeks for opaque feedback	AI-assisted self-review, structured submission, test credentials required	April 2026
Extensions	Created and managed in web dashboard	Managed via command-line tool, stored in code repository	Current standard

CRM Sync — Current Compliance Status

REQUIREMENT	STATUS	NOTES
App registered in Dev Dashboard	Done	
Config file (`shopify.app.toml`) in repository	Done	
Expiring tokens with automatic refresh	Done	Refreshes before expiry, not after failure
GDPR deletion webhooks implemented	Done	All three handlers with signature verification
Privacy policy published	Done	Hosted at crm-sync-docs.netlify.app
Protected customer data level requested	Needed	Must request Level 1 (name + email) in Partner Dashboard
GDPR webhooks declared in config file	Needed	Verify in shopify.app.toml
Billing via GraphQL	Needed	Not yet implemented
Minimum required scopes verified	Needed	Audit for unnecessary permissions
App listing complete	Needed	Screenshots, demo video, test credentials
Emergency contact provided	Needed	Email + phone for Shopify review team

Key Dates

DATE	WHAT HAPPENS	WHAT YOU NEED TO DO
Already passed (Feb 2025)	Scopes reviewed for necessity on every submission	Remove any permissions the app doesn't actively use
Already passed (Dec 2025)	Customer data scopes enforced for tracking pixels	Pixels accessing customer data need field-level approval
Already passed (Apr 1, 2026)	Expiring tokens mandatory for new public apps	Apps with never-expiring tokens will be rejected — CRM Sync already compliant
Current (Mar 2026)	Role-based access for partner organizations	Multi-user partner orgs need role setup
Current (Apr 2026)	New submission experience with AI self-review	Pre-submission automated checks flag common issues

What Each Change Means for Your Business

Expiring Tokens

Before: Your app got a permanent key to the store's data. If that key was ever leaked, it worked forever.

Now: Keys expire every 60 minutes and must be refreshed. This means:

- A leaked key stops working within an hour
- The app must handle refresh automatically (CRM Sync does this)
- Both the old key and the new key must be updated together on each refresh

Business impact: Better security with no change in functionality. But apps that don't implement refresh will simply stop working.

Protected Customer Data

Before: Request "read customers" and get everything — names, emails, phones, addresses.

Now: You must declare exactly which customer fields you need and justify why. There are three levels:

- **Level 0:** No customer personal data (just orders, products)
- **Level 1:** Name and email (required for CRM Sync's identity matching)
- **Level 2:** Plus phone and address (needed if syncing to CDPs that use phone/address)

Business impact: CRM Sync needs at least Level 1. Testing must happen on a real store (not a development store) because development stores bypass these restrictions.

Mandatory GDPR Webhooks

Before: Handling data deletion requests was optional.

Now: Your app must handle three specific requests from Shopify:

1. "Give us all the data you have for this customer" (data access request)
2. "Delete this customer's personal data" (deletion request)
3. "This store uninstalled your app — delete all their data within 48 hours" (shop deletion)

Business impact: CRM Sync already handles all three. Each request is verified for authenticity before processing.

Configuration as Code

Before: App settings lived in web forms. No history, no review process, no way to compare versions.

Now: Settings live in a file (`shopify.app.toml`) in the code repository. Changes are version-controlled and reviewable.

Business impact: You can see exactly what changed, when, and who approved it. Same config file is used across development and production.

Migration Checklist

For teams migrating from the old Partner Dashboard to the current Dev Dashboard:

Authentication:

- ☐ Implement expiring token refresh (60-minute access tokens, 90-day refresh tokens)
- ☐ Test that the app recovers from an expired token without errors
- ☐ Verify the app works in Chrome incognito mode (no pre-existing cookies)

Customer Data:

- ☐ Request the appropriate data access level (Level 1 or 2) in Partner Dashboard
- ☐ Verify the app handles missing/null fields gracefully (for unapproved fields)
- ☐ Test on a non-development store (dev stores bypass field restrictions)

GDPR Compliance:

- ☐ Implement all three data handling webhooks (data request, customer deletion, shop deletion)
- ☐ Verify each webhook checks request authenticity before processing
- ☐ Declare webhook URLs in the config file

- [ ] Publish a privacy policy and link it from the app listing

Billing:

- [ ] Switch to GraphQL subscription API
- [ ] Test billing with test mode enabled on development store
- [ ] Disable test mode before submitting for review
- [ ] Support plan upgrades and downgrades without reinstalling

App Listing:

- [ ] App icon (1200x1200px)
- [ ] 3-6 screenshots (1600x900px) showing actual app UI
- [ ] Demo screencast with English or English subtitles
- [ ] Test credentials that the review team can use
- [ ] Emergency contact email and phone number

Configuration:

- [ ] Generate or create `shopify.app.toml` with correct settings
- [ ] Set API version to current supported version (2025-04 or later)
- [ ] Disable legacy install flow
- [ ] List only the minimum required permission scopes

Downloadable Audit Checklist

A comprehensive checklist covering all 10 requirement areas (100+ items) is available for download:

File: `docs/shopify-app-checklist.llm.md`

This checklist can be:

- Used as a team tracking document for submission readiness
- Fed to an AI assistant alongside your codebase for automated compliance checking
- Added to your pull request template for team review before each release

---

Technical reference: FEATURE-SPEC-UA-MIGRATION.md Audit checklist: shopify-app-checklist.llm.md

---